PrivLens

PII Discovery & Privacy Evidence Inventory Engine

Problem Statement PS-019 | Category: Cyber Security / Privacy Engineering

Team Name	[Your Team Name]
Live Project	https://privylens.onrender.com/
Pseudocode Snippet	docs/PSEUDOCODE_SNIPPET.md
Demo Video	[Add your YouTube link]

1. Executive Summary & Challenge

Organisations keep personal data in spreadsheets and databases that are rarely fully documented. Privacy officers need technical evidence of **where** personal data lives and whether each field has a declared business purpose and retention schedule.

PrivLens scans structured datasets (CSV and SQLite), discovers Personally Identifiable Information (PII) across 5 predefined data classes, links candidate fields to declared purposes and retention schedules, produces an actionable evidence inventory, and reports per-class Precision and Recall against a manually labelled ground truth.

Key capabilities

- **Multi-source support:** synthetic CSV files, SQLite databases and user-uploaded custom files.
- **Upload & Scan:** drag-and-drop .csv and .db / .sqlite files in the web UI, or scan from the CLI.
- **Configurable evidence checklist:** declarative YAML rules combining header heuristics, regex, checksums and sample match ratios.
- **RoPA purpose & retention mapping** against declared governance metadata.
- **Evidence gap detection:** unregistered shadow data, missing purposes, missing retention policies.
- **Benchmark evaluation:** per-class Precision, Recall and F1-Score.
- **Interactive dashboard:** Chart.js analytics, filterable inventory, evidence inspector, rule sandbox, dark/light mode.

The 5 official PS-019 personal data classes

Code	Class	Covers
PID	Personal identity	Name, date of birth, gender, age
CNT	Contact information	Email address, phone number
GID	Government identifiers	Aadhaar, PAN, passport, voter ID, driving licence
FIN	Financial information	Bank account number, IFSC, card number, UPI ID
LOC	Location / address	Postal address, PIN code, geo-coordinates

Fields matching none of these classes are labelled *not personal data*.

2. Key Requirements & Boundary Compliance

Requirement	Implementation in PrivLens	Status
Structured data sources	CSV and SQLite (.db, .sqlite, .sqlite3), synthetic and user-uploaded	Verified
5 personal data classes	PID, CNT, GID, FIN, LOC; everything else labelled not personal data	Verified
Configurable evidence checklist	YAML rules: header heuristics, regex, checksum validators (e.g. Luhn), sample match ratios	Configured & tested
Purpose & retention mapping	Governance linker driven by governance_registry.yaml	Verified
Evidence gap detection	Flags shadow data, missing purposes, missing retention, with recommendations	Verified
Quantified evaluation	Per-class Precision, Recall, F1-Score and TP / FP / FN counts	Fully quantified
Reporting & export	PDF, Markdown and JSON reports from CLI and dashboard	Verified
Automated testing	12 unit tests: validators, scanners, governance, uploads, metrics	Passing
No legal determinations	Evidence compilation only; no lawful-basis decisions or cross-border transfer inference	Boundary respected

3. Architecture & Discovery Pipeline

1. Data Source	CSV file / SQLite database / web or CLI upload
2. Scanner Engine	csv_scanner (CSV profiler) and sql_scanner (SQLite schema and sample profiler); up to 100 values sampled per column
3. Rule Matcher	config/detection_rules.yaml: header heuristics, regex patterns, checksum validators (Luhn, Aadhaar, geo, IPv4), sample match ratios
4. Classification	PID, CNT, GID, FIN, LOC or not personal data; confidence score with masked sample preview
5. Governance Mapper	config/governance_registry.yaml: links fields to purposes, retention schedules, owners; detects evidence gaps
6. Benchmark Evaluator	datasets/ground_truth.json: per-class Precision, Recall, F1-Score; macro and micro averages
7. Reporters & Dashboard	JSON / Markdown / PDF reports; Flask REST API and interactive web dashboard

How a column is scored

Each rule produces a score from the header match and the sample match ratio: **header and value match** = header_weight + value_weight x ratio; **header only with some value support** = 0.9 x header_weight + value_weight x ratio; **header only** = 0.7 x header_weight; **value only** = value_weight x ratio. A rule is recorded as evidence at a score of 0.35 or more, and a column is classified as personal data at a confidence of 0.50 or more. Every classification carries its evidence: the rule, the header match, the sample match ratio and the validator that confirmed it. Sample values are masked before display.

Governance evidence gaps

Gap type	Severity	Trigger
UNREGISTERED_SHADOW_DATA	Critical	Candidate PII with no entry in the governance registry
MISSING_PURPOSE	High	Registered PII field with no declared business purpose
MISSING_RETENTION	High	Registered PII field with no retention limit or deletion trigger

4. Experimental Evaluation & Benchmark Results

Detection accuracy is evaluated against a manually labelled ground-truth benchmark (command: `python cli.py evaluate --export`).

Code	Data class	TP	FP	FN	Precision	Recall	F1
PID	Personal identity	6	0	0	100.0%	100.0%	100.0%
CNT	Contact information	4	0	0	100.0%	100.0%	100.0%
GID	Government identifiers	7	0	0	100.0%	100.0%	100.0%
FIN	Financial information	8	0	0	100.0%	100.0%	100.0%
LOC	Location / address	6	0	0	100.0%	100.0%	100.0%

- Precision = TP / (TP + FP); Recall = TP / (TP + FN); F1 = 2 x Precision x Recall / (Precision + Recall).
- **Overall:** Macro Precision 100.0% | Macro Recall 100.0% | Macro F1 100.0%.
- **Evaluated:** 44 fields (29 personal data fields + 15 not personal data fields).

5. Repository Structure

```
config/
  detection_rules.yaml        detection rules and thresholds for 5 classes
  governance_registry.yaml    declared purposes, retention, data owners
datasets/
  synthetic/                  synthetic CSV files and SQLite database
  ground_truth.json           manually labelled benchmark
  generate_datasets.py        deterministic synthetic data generator
privlens/
  models.py                   dataclasses (DiscoveredField, InventoryItem, ...)
  scanner/                    engine, csv_scanner, sql_scanner, rule_matcher
  governance/mapper.py        governance linker and gap analyzer
  evaluation/metrics.py       precision, recall, F1 calculator
  reporters/                  json, markdown and pdf reporters
web/
  app.py                      Flask REST API server
  static/                     app.js (SPA + Chart.js), custom.css
  templates/index.html        Tailwind dashboard
cli.py                        command line interface
tests/                        12 unit tests
docs/PSEUDOCODE_SNIPPET.md    pseudocode snippet and mentor briefing
reports/                      generated inventory and technical reports
TECHNICAL_REPORT.md  requirements.txt  README.md
```

6. How to Run the Demonstration

Option A: live dashboard (no install)

Open https://privylens.onrender.com/. The free tier sleeps when idle, so the first load can take 30-50 seconds.

Option B: run locally (Python 3.10+)

```
pip install -r requirements.txt
python cli.py generate-data
python cli.py serve --port 5000
# open http://127.0.0.1:5000
```

Option C: CLI

```
python cli.py scan --export
python cli.py evaluate --export
python cli.py scan --path uploads/my_customers.csv
python -m unittest discover tests
```

7. Legal Boundary & Privacy Engineering Disclaimer

PrivLens is a technical discovery and evidence compilation tool for human privacy officers, compliance auditors and data stewards.

- It does **not** make automated lawful-basis decisions (for example Consent Art. 6(1)(a) versus Legitimate Interests Art. 6(1)(f)).
- It does **not** infer universal cross-border data transfer flows without verified network telemetry.
- All findings are empirical observations that support human decision-making and RoPA maintenance.